

PIEDPIN

Let's try CISSP!

なぜCISSPを学ぶのか

- ✓ CISSP(Certified Information Systems Security Professional)とは、
世界標準の**セキュリティ・プロフェッショナル認定**です。
- ✓ (ISC)²（国際情報システムセキュリティ認証コンソーシアム、
International Information Systems Security Certification Consortium）が認定を行っています。
- ✓ 情報セキュリティ専門家が共通言語として利用している
『(ISC)² CISSP CBK』を理解している者に与えられる資格です。
- ✓ 2004年6月に、米国規格協会（ANSI）より
ISO/IEC17024の認証を受け、信頼度がより高くなりました。
(https://japan.isc2.org/cissp_about.html)
- ✓ 2022年7月1日現在、日本のCISSPは**3,699**人です。

(ISC)² が展開する資格ソリューション



国際的に認められた情報セキュリティ・プロフェッショナル認定資格です。米国規格協会（ANSI）よりISO/IEC17024の認証を受けた。



ベンダーフリー・カントリーフリーの情報セキュリティの資格です。情報セキュリティに従事しないが、組織を理解し、適切なコミュニケーションを行う。



クラウドサービスを安全に利用するために必要な知識を体系化した資格です。



ソフトウェアの脆弱性に端を発したセキュリティインシデントの増加や、政府や重要インフラにおけるセキュアなソフトウェアニーズに対応する資格です。

(ISC)² CISSP CBK ドメイン



ドメイン 1
セキュリティとリスク
マネジメント



ドメイン 2
資産のセキュリティ



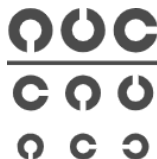
ドメイン 3
セキュリティアーキ
テクチャとエンジニ
アリング



ドメイン 4
通信とネットワー
クのセキュリティ



ドメイン 5
アイデンティティと
アクセスの管理



ドメイン 6
セキュリティの評
価とテスト



ドメイン 7
セキュリティの運用



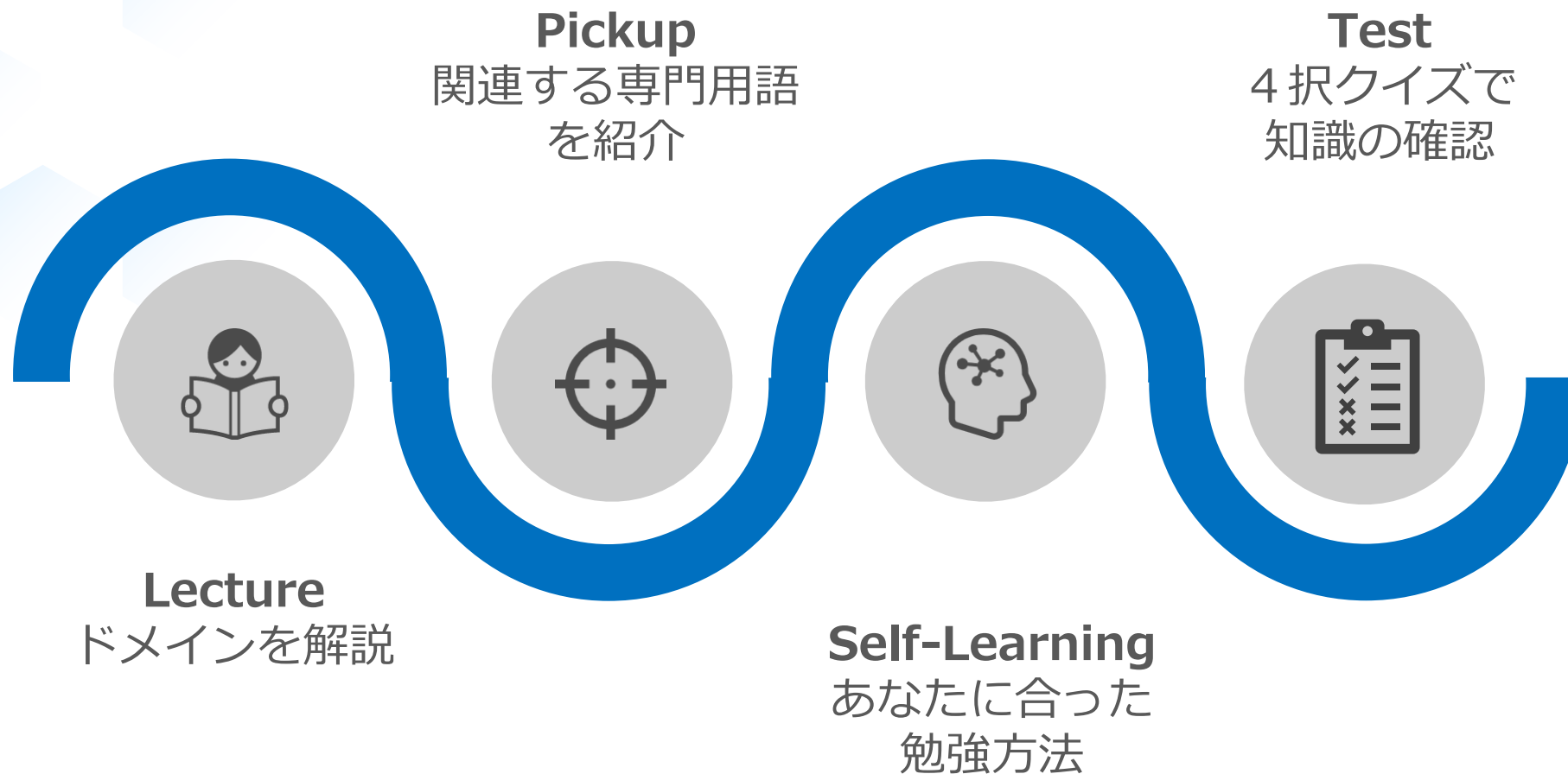
ドメイン 8
ソフトウェア開発
セキュリティ

あなたのゴールと本レッスンの内容

- ✓ 情報セキュリティ初心者のために設計されたCISSP講座
経験者からすると“当たり前”と感じる内容も含まれます。
- ✓ 本レッスンの対象は、CBKのドメイン 2 です。
他のドメインのレッスンは対象外となります。
- ✓ CISSP合格のためのアップグレードが必要です。
現代のセキュリティの関心、流行、考え方を織り込みます。



レッスンの流れ



ドメイン別試験比重



ドメイン 1
セキュリティと
リスクマネジメント

16%



ドメイン 2
資産のセキュリティ

10%



ドメイン 3
セキュリティアーキテク
チャとエンジニアリング

13%



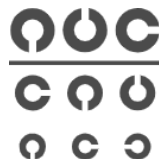
ドメイン 4
通信とネットワーク
のセキュリティ

13%



ドメイン 5
アイデンティティと
アクセスの管理

13%



ドメイン 6
セキュリティの評価
とテスト

12%



ドメイン 7
セキュリティの運用

13%



ドメイン 8
ソフトウェア開発
セキュリティ

10%



情報と資産の 識別と分類

分類することの重要性を知ろう

2.1 情報と資産の識別と分類

2.1.1 情報と資産

● 情報と資産

情報 (Information)

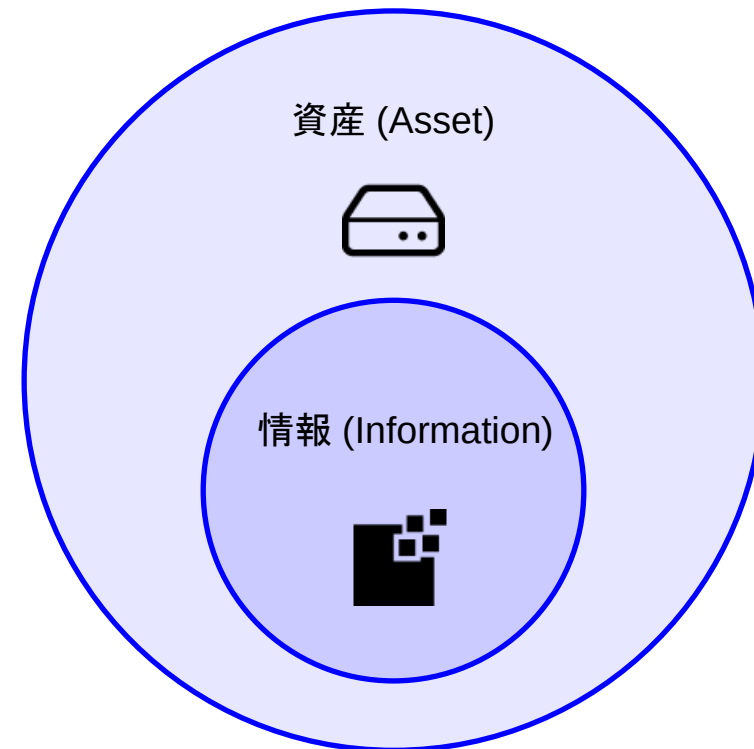
- 情報はデータが意味を持つ形に変換されたものです。
- 例：財務報告書、顧客データ、メール内容、研究レポート、機密文書

資産 (Asset)

- 組織にとって価値があり、保護が必要なものです。
- 例：サーバー、ネットワーク機器、ソフトウェアアプリケーション、従業員、顧客リスト、知的財産

コラム：情報と資産と情報資産

“情報資産”は、資産から見たときの情報を指していますので、つまり情報と同じ意味と考えて問題ありません。



2.1 情報と資産の識別と分類

2.1.1 情報と資産

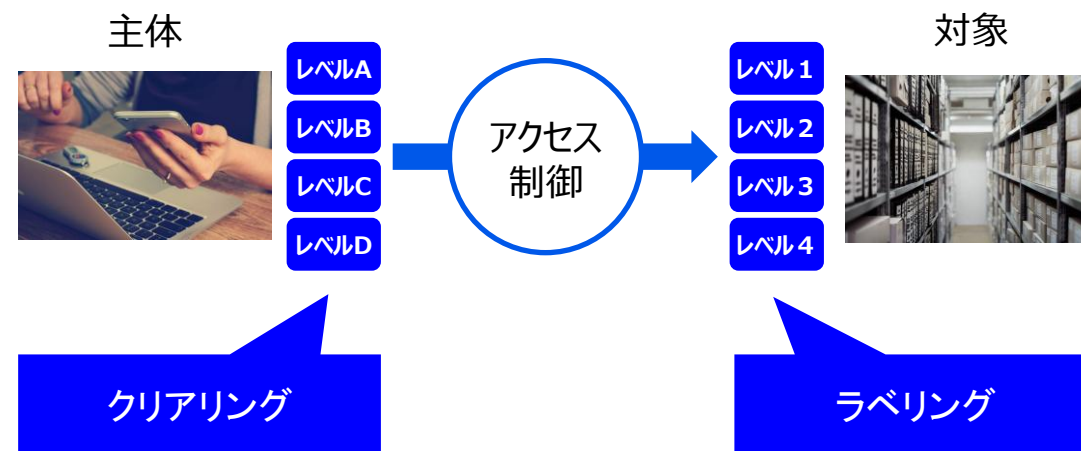
● アクセス制御

主体 (subject)

- 主体 (subject) とは、人間やコンピューターなど、データを操作する側を示す概念です。

対象 (object)

- 対象 (object) とは、データそのものやドキュメントなど、データを操作される側を示す概念です。



コラム：人間＝主体？

人間が常に主体というわけではありません。要求の受け取り手が人間なら、人間も対象になります。
何が、何にアクセスしているのかによって主体と対象は異なります。

2.1 情報と資産の識別と分類

2.1.2 ラベリング

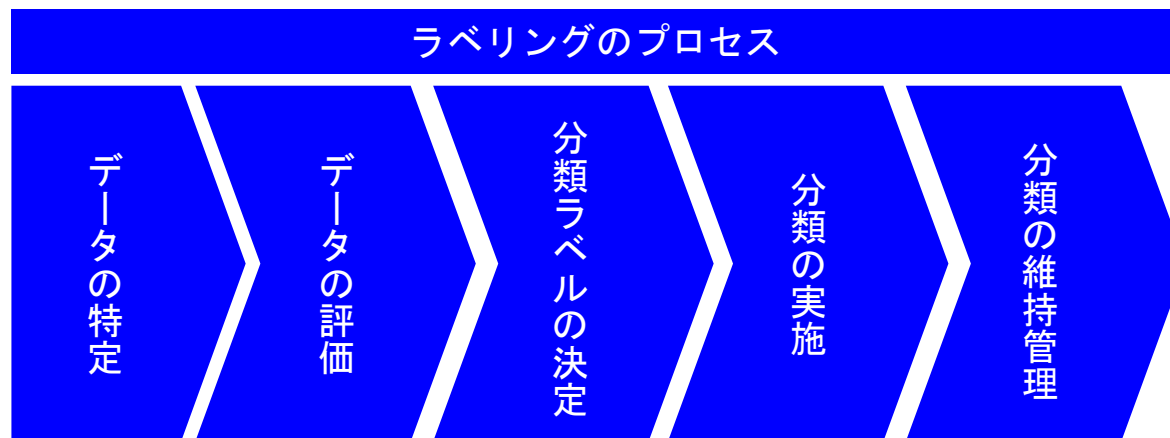
● ラベリングの目的

資産やデータを分類する目的は、機密性の確保、法的および規制要件の遵守、リスク管理、効率的な管理とアクセス制御になります。

● ラベリングのプロセス

- ① データの特定：組織内の全てのデータを特定し、リストアップします。
- ② データの評価：各データの価値、感度、法的要求事項を評価します。
- ③ 分類ラベルの決定：データの評価結果に基づいて、適切な分類ラベルを決定します。
- ④ 分類の実施：決定されたラベルをデータに適用し、文書化します。
- ⑤ 分類の維持管理：データの分類が適切に維持されるよう、定期的なレビューと更新を行います。

データ分類の目的	内容
機密性の確保	機密性の高いデータが不適切に取り扱われないようにする。
法的および規制要件の遵守	法律や規制に基づいて必要な保護措置を講じる。
リスク管理	データの価値や感度に応じたリスク対策を講じる。
効率的な管理とアクセス制御	適切なアクセス制御を実施し、データの取り扱いを効率化する。



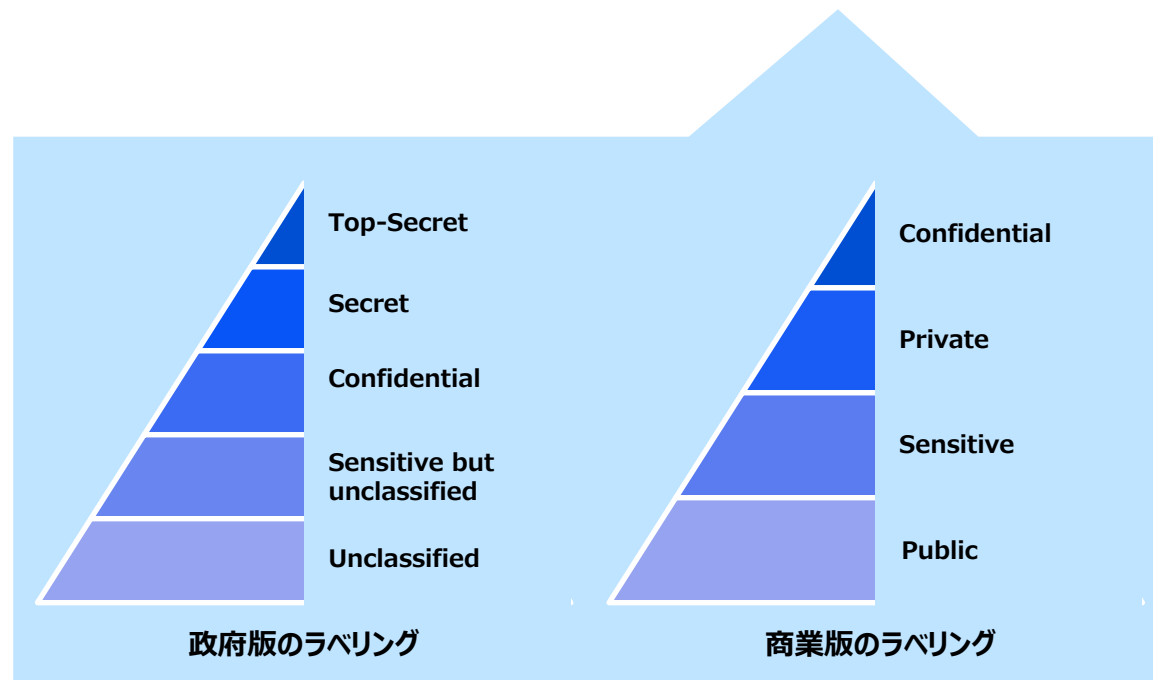
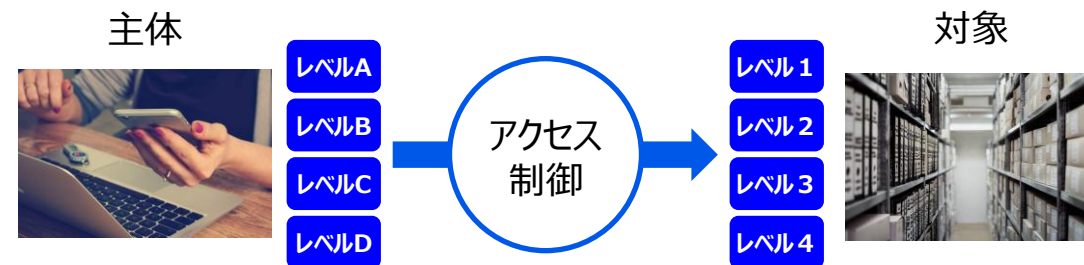
2.1 情報と資産の識別と分類

2.1.2 ラベリング

● ラベリング

ラベリング (Labeling)

- オブジェクトを適切な機密レベルに割り当てることです。
- ラベリングの区分と定義は、政府系と商業系で異なります。
- 政府の目的は統治であり、社会データは公開ではなく仕分けを行っていないという扱いになります。一方で、商業の目的は自身の資産であり、社内データは少なくとも認知しておく必要があることから、定義が分かれます。



2.1 情報と資産の識別と分類

2.1.2 ラベリング

● ラベリング手法の伝達

データ分類をするのは特定のチームに限ったことではありません。組織に携わる者は、そのプロセスや概念を理解する必要があります。

全社的なポリシーの策定、定期的なトレーニング、自動化ツールの活用、監査とレビューが必要です。

伝達方法	内容
全社的なポリシーの策定	明確なデータ分類ポリシーを策定し、全社的に周知徹底します。
定期的なトレーニング	従業員に対して定期的なトレーニングを実施し、データ分類の重要性を理解させます。
自動化ツールの活用	データ分類を支援する自動化ツールを導入し、効率的な管理を行います。
監査とレビュー	データ分類の実施状況を定期的に監査し、必要に応じて改善を行います。

2.1 情報と資産の識別と分類

2.1.3 ラベルの判別

● 物理的なラベリング

シール

- ・ 情報媒体に対して、「社外秘」と書かれたシールを貼ります。
- ・ 付け替えは極力せずに、不要になったら復元できないように破棄します。

ハンコ

- ・ 機密文章の表紙に、「機密」と押印します。

● 電子的なラベリング

ヘッダー・フッター

- ・ 文章ソフトでヘッダー・フッターに「社外秘」と記載する。
- ・ 印刷された場合にも物理的なラベリングの働きをする。
- ・ データ損失防止（DLP）システムにより、特定文字を含む社外に持ち出しを検知することができます。

デスクトップ

- ・ 専用端末のデスクトップ画面を目的別に識別できるようにします。



2.1 情報と資産の識別と分類

2.1.4 クリアランス

● クリアランス

クリアランス(Clearance)

- クリアランスは、個人が特定のレベルの機密情報や資産にアクセスする権限を持つことを公式に認めるプロセスです。
- サブジェクトに対して信頼を基に機密レベルを振り分けた対象にアクセス許可として定義することです。
- 組織の機密情報や重要な資産を保護するために、適切な権限を持つ人だけがアクセスできるようになります。

クリアランス手法	内容
バックグラウンドチェック	個人の過去の行動、信用、犯罪歴などを確認し、信頼性を評価します。
トレーニング	セキュリティ意識向上のためのトレーニングを提供し、クリアランスに伴う責任を理解させます。
認定	評価とトレーニングの結果に基づき、適切なクリアランスレベルを認定します。
モニタリングと再評価	定期的にクリアランスを見直し、継続的な適格性を確認します。

コラム：セキュリティ・クリアランス法案

「クリアランス」という言葉を最近聞く機会があったのは、セキュリティ・クリアランス法案ではないでしょうか？

セキュリティ・クリアランス（SC）制度は、政府が信頼性を審査・確認した者に、秘密情報へのアクセスを認める制度です。

元々、特定秘密保護法でSC制度を規定はありましたが、対象となる経済・技術分野の情報は公務員や一部の防衛に関わる民間団体に限られていたため、「重要経済安保情報」を定義し、見直されることになりました。

https://www.cas.go.jp/jp/seisaku/keizai_anzen_hosyo_sc/dai10/siryoku.pdf



情報と資産の プロビジョニング

組織の資産がどこにあるのか把握しよう

2.2 情報と資産のプロビジョニング

2.2.1 所有権

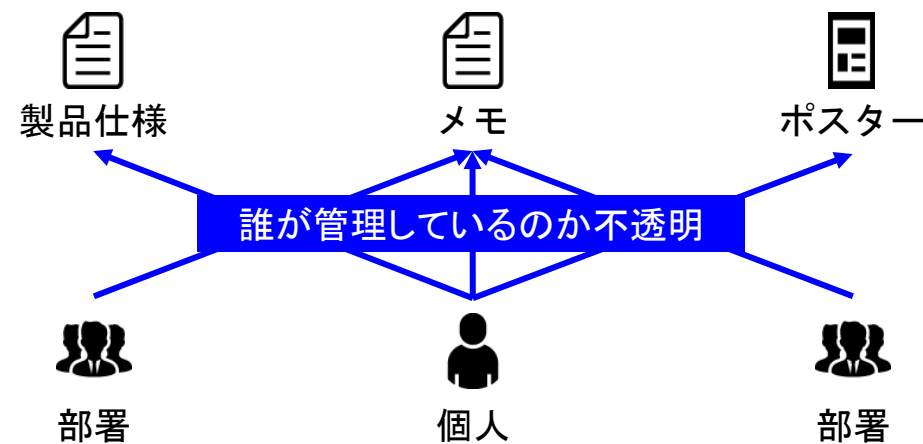
●資産インベントリ

所有権

- 情報の所有権とは、組織内の**情報に対する**責任と管理権限を持つ個人や部門を指します。
- 資産の所有権とは、組織内の**物理的およびデジタル資産に対する**責任と管理権限を持つ個人や部門を指します。

所有権を明確にする目的

- 資産に対するアクセス権限を管理し、適切なユーザーのみがアクセスできるようにします。
- 資産の使用状況を監査し、法的規制要件に準拠することができます。
- セキュリティインシデントが発生した場合の対応計画を策定し、迅速に対応できる体制を整えます。



2.2 情報と資産のプロビジョニング

2.2.2 資産インベントリ

●資産インベントリ

インベントリ管理

- IT資産に関する情報を一元的に管理する仕組みです。
- 物理端末上のソフトウェアのライセンスやバージョン等も管理対象になります。

インベントリ管理のメリット

- 不必要なライセンスやソフトウェアを特定し、コストの節約になります。
- セキュリティルールを無視したソフトウェアを検知することで、セキュリティを強化することができます。



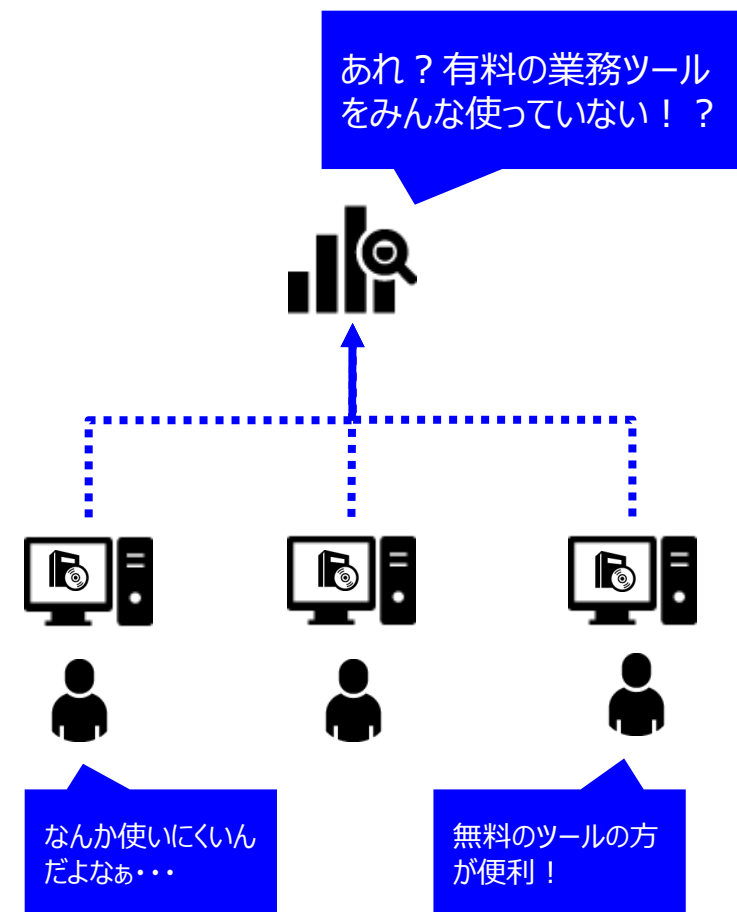
ハードウェア

- 機器の名称
 - スペック
 - 利用者名
 - IPアドレス
- など



ソフトウェア

- 機器のOS
 - OSの更新状況
 - アプリケーション
 - ライセンス情報
- など



2.2 情報と資産のプロビジョニング

2.2.2 資産インベントリ

● 資産インベントリ

IT資産管理

- 資産管理とは、企業や組織内の資産の状況を把握し、管理することです。
- IT資産管理は組織はライフサイクル全体を通じた情報資産の管理、およびログ分析ツールとの統合による監査情報の収集と保存とレポート作成を含みます。
- サービスデスクで実施している問題管理や変更管理、構成管理の運用作業を総合的に管理するツールを組み合わせることで対象機器を明確にします。



資産ライフサイクル管理



データライフサイクルの 管理

データは生まれ、使われ、そして消える
ことを理解しよう

2.3 データライフサイクルの管理

2.3.1 データの役割

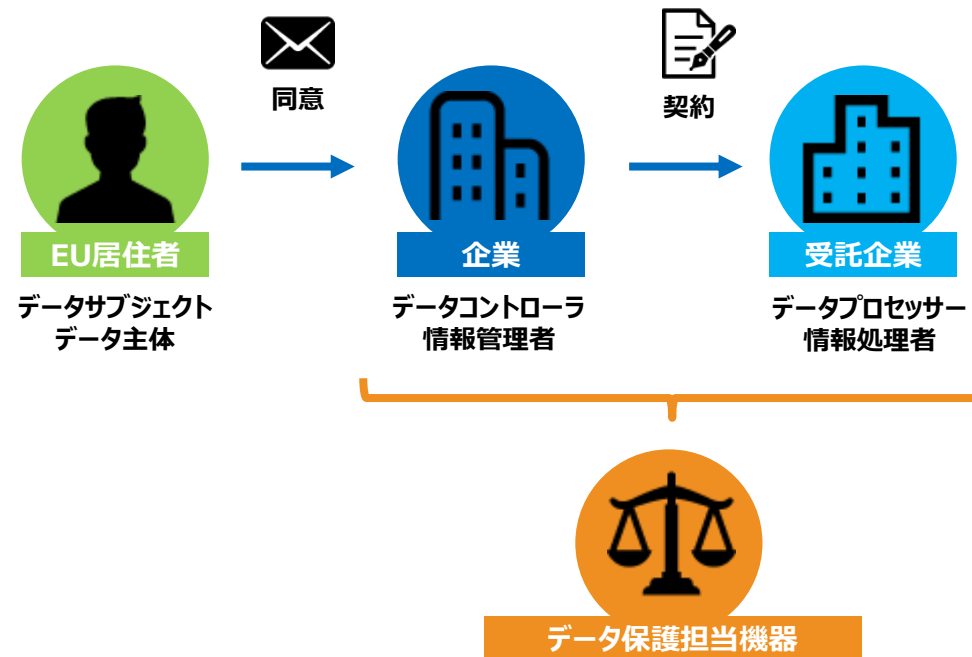
● 役職と責任

ユーザー（User）

- ・ システムの利用者であり、システムで利用するデータの保持者です。
- ・ ユーザー自身は従業員であることもあれば、一般的なユーザーであることもあります。
- ・ ユーザーは「パスワードは付箋に張らない」「パスワードは使いまわさない」といった基本方針に従ってデータを保護することが求められます。

データコントローラー／データプロセッサー

- ・ データを管理・操作するシステムや組織です。一般データ保護規則（GDPR）内で用いられる用語です。
- ・ 例えば、ある企業が自社の従業員のデータを、クラウドのアカウントデータベースサービスを利用していたとします。この時、データを扱うのは企業になるためデータコントローラーになり、実際にデータを処理しているのはクラウド事業者になるためデータプロセッサーに当たります。



2.3 データライフサイクルの管理

2.3.1 データの役割

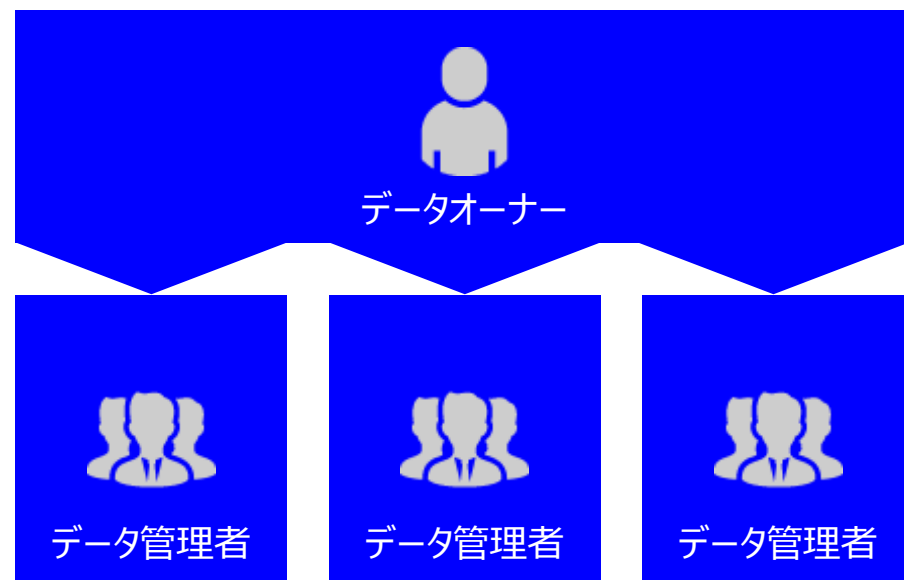
● 役職と責任

データオーナー (Data Owner)

- データオーナー (Data Owner) 、もしくは資産オーナー (Asset Owner) とは、情報資産の管理についての最終的な責任を負っている人のことです。
- 情報を分類し、セキュリティラベルを適切にマークし、データの機密性、完全性、可用性を確保するための保護手段を定義して、それを実装します。
- データオーナーは通常、社長、CEO、もしくは部門長になります。
- 機密データを保護することになるセキュリティポリシーの実施に関して適切な注意を怠った場合、過失の責任を負います。

データ管理者 (Data Custodian)

- データ保護を目的としたタスクを日々完了できるように操作する者です。
- 日常的な運用責任はデータカストディアン (Data Custodian) に委任します。



2.3 データライフサイクルの管理

2.3.2 データの収集

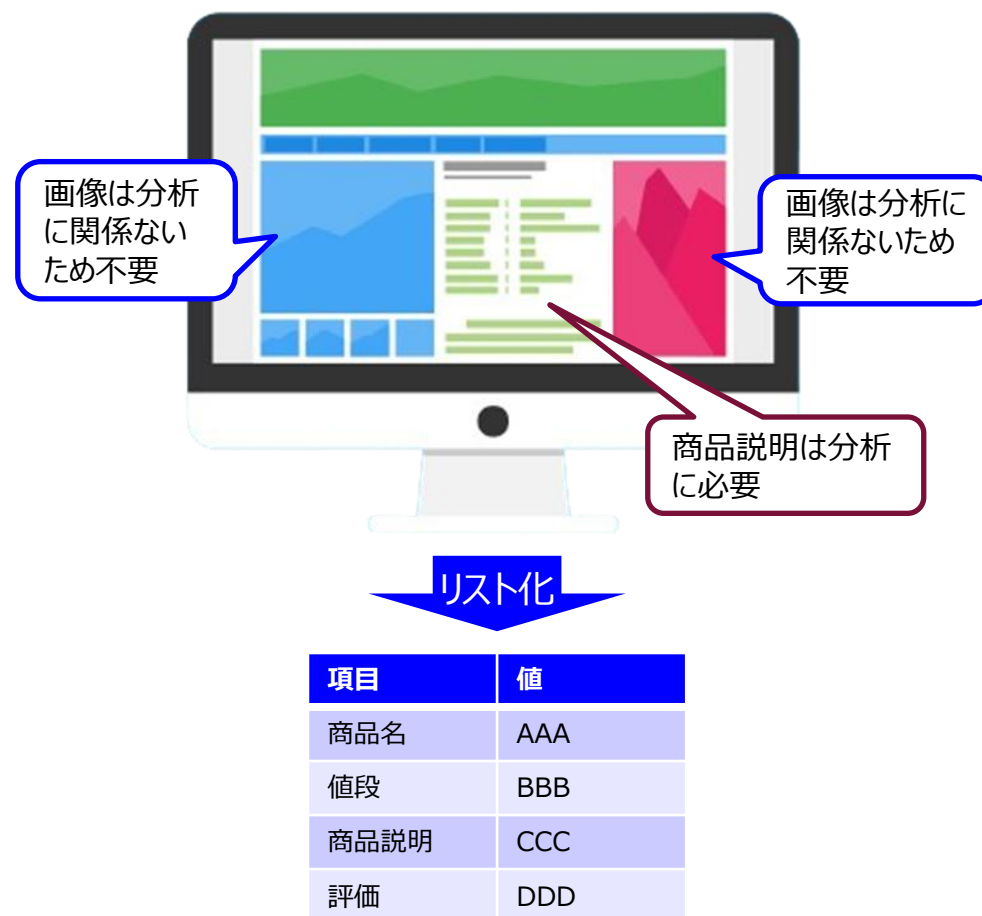
●データの収集

データの収集方法

- 官公庁のWebサイトや独自にデータを分析を行っている組織が公開しているWebサイトから資料ダウンロードする。
- サービスのログ履歴とアカウント情報を紐づけることができます。自身のEコマースサイトでの商品と購入者情報を紐づけることができます。
- スクレイピングをする。

スクレイピング

- スクレイピングとは、Webページからテキストを抽出し、分析を行うモノです。
- ソーシャルメディア上の投稿やWebサイトのレビュー情報は、ボタンやアイコンなどのWebページ特有のパーツを含みます。
- プログラムで特定の部分だけを抽出し、一覧化します。
- スクレイピングを禁止しているサービスもあるので、利用規約を確認したうえで検討しましょう。



2.3 データライフサイクルの管理

2.3.3 データの所在

●データの所在

データの種類

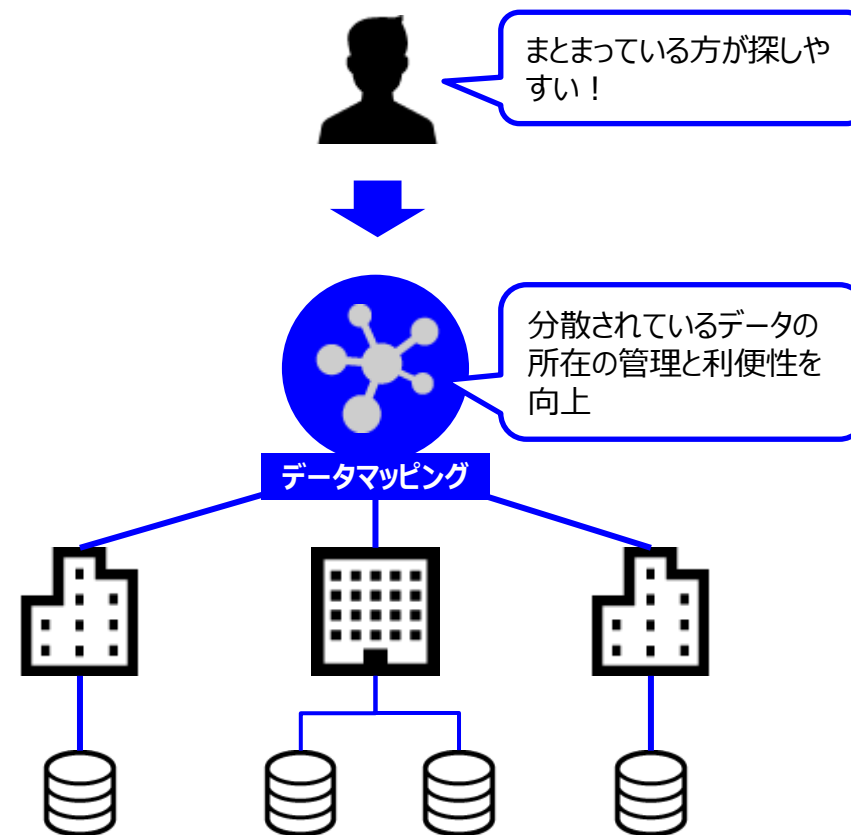
- データの種類は、データが保存されている物理的または仮想的な場所を指します。
- オンプレミスのサーバー、クラウドストレージ、外部ストレージデバイスなど、あらゆるデータストレージメディアを含みます。

データマッピング

- すべてのデータの保存場所をマッピングし、どのデータがどこに保存されているかを明確にします。

クラウドストレージの利用

- クラウドストレージを活用してデータの可用性とスケーラビリティを向上させます。クラウドプロバイダを選定し、データの移行計画を立て、セキュリティ設定を行います。

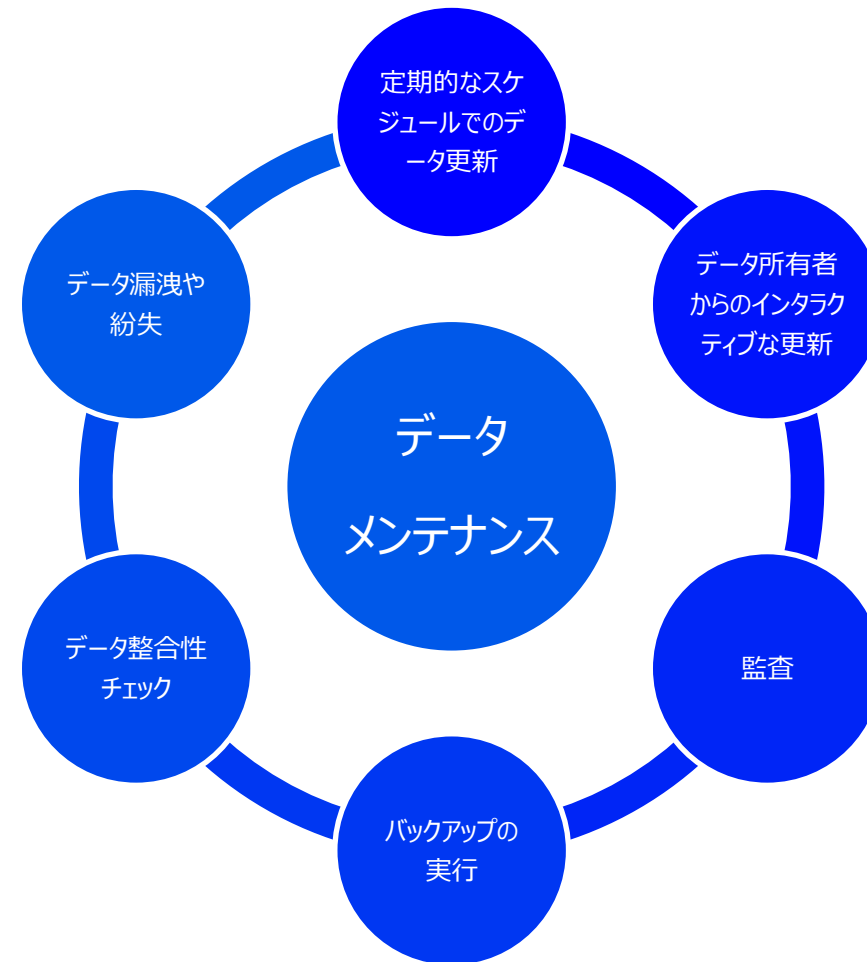


2.3 データライフサイクルの管理

2.3.4 データのメンテナンス

●データのメンテナンス

最新のデータに対応し、整理し続けるという意味が含まれます。データベースを最新の状態に保ち続けることで、データに基づく意思決定の精度をあげることができるでしょう。システム管理の観点では、定期的なスケジュール/バッチ、データ所有者からのインタラクティブな更新、監査、バックアップの実行、データ整合性チェック、データ漏洩や紛失の管理が含まれます。



2.3 データライフサイクルの管理

2.3.5 データの保持

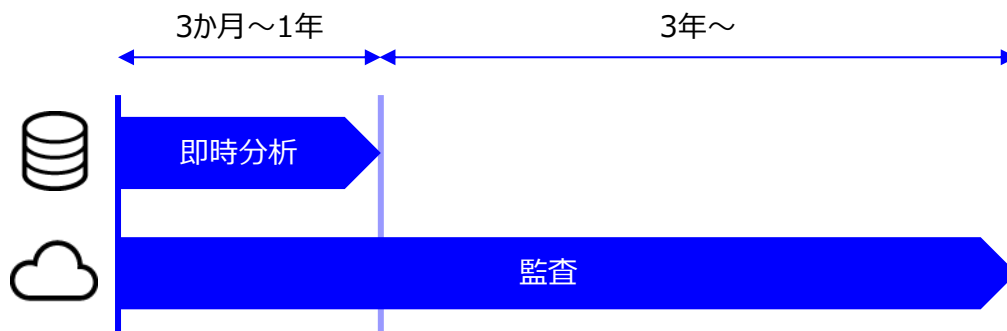
●データの保持

データの保存期間

- 重要なデータは必要な限り、法律で義務付けられている限り保持し、維持しなければなりません。

分析用と監査用のデータベース

- 即時分析できるデータベースと、長期保存し監査できるデータベースの2タイプの運用が推奨されます。
- 分析用のデータベースはオンラインであり、常に利用ができる状態にします。監査用のデータベースはオフラインであり、保存期間にかかるコストを削減します。



法令もしくは規則	保管期間に関する文言抜粋
刑事訴訟法 第百九十七条 3	三十日を超えない期間
サイバー犯罪に関する条約 第十六条 2	必要な期間（九十日を限度とする。）
PCIDSS v4.0	少なくとも 1 年間保持
不正アクセス禁止法	3年間
内部統制関連文書、有価証券報告書とその付属文書の保存期間及び電子計算機損壊等業務妨害罪	5年間
電子計算機使用詐欺罪	7年間
『不当利得返還請求』等民法上の請求権期限、及び総勘定元帳の保管期限	10年間

2.3 データライフサイクルの管理

2.3.6 データの残留性

●データの残留性

データの残留性とは、データを削除するための手段を超えて存続するデータです。

セキュリティの専門家は、さまざまな種類のメモリとストレージの残留特性を理解し、データを回復不能にする手順を理解する必要があります。

項目	内容
セキュリティリスク	残存データが復元されることで、機密情報が漏洩するリスクがあります。
プライバシー保護	個人情報保護法やGDPRなどの規制を遵守するために、データ残存を管理することが重要です。
法的コンプライアンス	特定の業界や国の法的要件を満たすために、データ残存を適切に処理する必要があります。

データ残留の危険性

2.3 データライフサイクルの管理

2.3.6 データの残留性

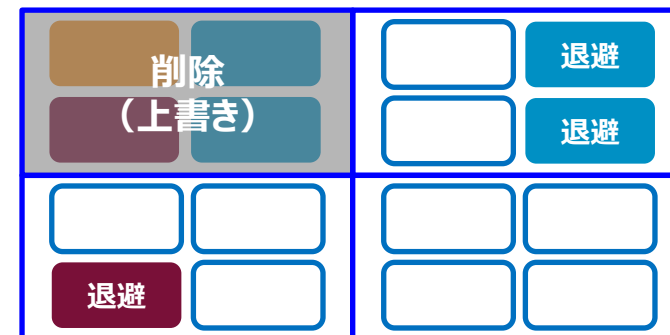
●データの残留性

ATAセキュア消去 (ATA Secure Erase)

- SSDなどATA規格のディスクにおいてソフトウェア操作でデータ削除する方法です。SSD (Solid State Drive) は、半導体素子メモリを使った記憶媒体であり、フラッシュメモリ (EEPROM) とDRAMを組み合わせたものです。
- 不良ブロックや、一部が上書きされたブロックの残り部分、ディレクトリ領域など、ディスク上のすべてのトラックを上書きできます。

コラム：SSDでのデータ削除

SSDでの削除はブロック単位で行います。ブロック内には、本来削除したくないデータもありますから、ブロック内の削除しないデータをほかのブロックにコピー（退避）して、対象のブロックを削除します。しかし、フラッシュメモリは記憶素子データの書き込み回数に上限があり、同じブロックを何回も書き込みし続けると使えなくなります。そのため、書き込み回数がSSD内で均一になるようにウェアレベリング（摩耗平滑化）されます。その結果、上書きしようとしても退避され続けられ、いつまでたってもすべてのデータを上書きすることはできません。そのため、SSDの全データ削除する際にはウェアレベリングを無効化します。



2.3 データライフサイクルの管理

2.3.7 データの破棄

●データの破棄

不要となったシステムデータを安全に削除する方法です。破棄した際は完全に破壊したことがわかるよう破損したディスクの写真などを保管しておくことも重要です。

種類		内容
消去	Erasing	システム上でファイルを削除する（ゴミ箱に入れる）ことです。
クリア、上書き	Clearing、Overwriting	システム上で上書きする（上書き保存）ことです。通常、データを消去するか、0または1で上書きします。ただ、復元できる可能性を完全に排除したわけではありません。
パージ	Purging	消磁や暗号化消去など、ディスクを壊さずにデータを完全（物理的に回復不可能）に削除することです。消磁とは、磁気メディアに強力な磁気を当てることです。消磁はSSDに影響を与えません。
破壊	Destruction	記憶媒体を物理的に破壊することです。

2.3 データライフサイクルの管理

2.3.7 データの破棄

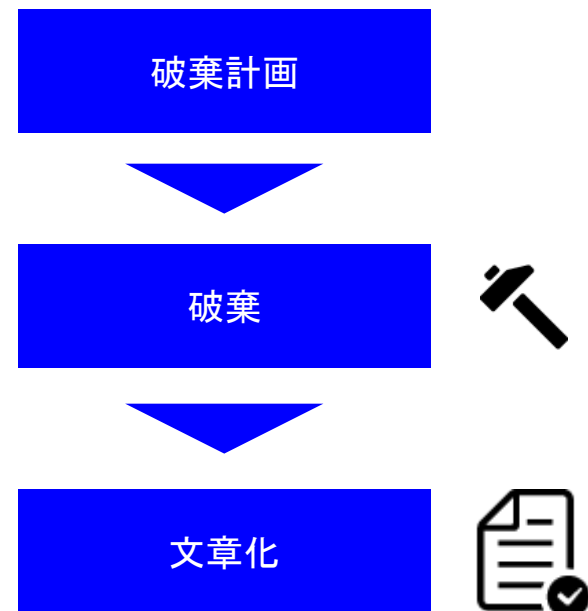
●データの破棄

暗号化消去

- 読み取れなくなった状態にすれば、破棄されたデータと同じことになります。
- 暗号化の技術を利用すれば、読み取れないデータ、つまり、破棄されたデータを作ることができます。
- ただし、破棄されているといってもその復元力は暗号化の強度に依存します。

文章化

- 破棄が完了したら、媒体廃棄ことがわかる証明書を文章化しておきます。
- 証明書には媒体のシリアル番号、媒体の種類、データ抹消処理方法、検証方法等を記載します。
- 個人情報保護法への適用や情報漏えい事件した際に、確実に破棄したことを示す証明に利用されます。



2.3 データライフサイクルの管理

2.3.7 データの破棄

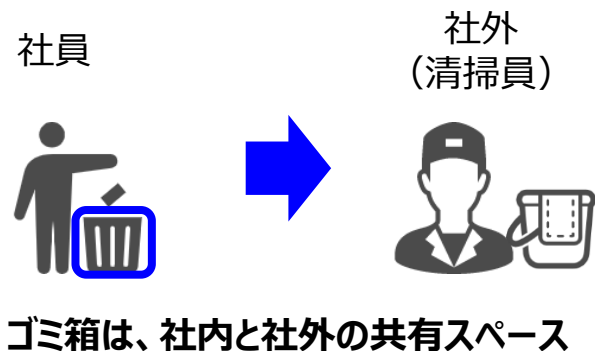
●データの破棄

ダンプスターダイビング（スカベジング）

- ゴミ箱の中から、機密文書などの紙媒体に記録された重要情報を見つけるソーシャルエンジニアリングの一種です。
- ゴミ箱への廃棄は、無意識に破棄したものと感じますが、実質的には復元可能な状態です。機密情報を含む文章などは、シュレッダーにかけ漏洩しないことが重要です。
- ストリップカットシュレッダーは、紙を垂直ストリップにカットします。クロスカットシュレッダーは、垂直方向と水平方向の両方をカットする方法、ストリップカットよりも安全です。ただし、刈り取り方の話ですので、細かくても復元されないわけではありません。

コラム：イランアメリカ大使館人質事件

1979年11月4日にイランのテヘランにて、イスラム革命防衛隊率いる暴徒化によってアメリカ大使館の人質事件です。大使館員や領事館員、海兵隊員らは、大使館の建物を占拠される前に、大量の各種機密書類やアメリカ合衆国ドル紙幣をシュレッダーにかけ処分にした。しかし、シュレッダーにかけられた書類の多くは、イラン当局に動員された協力者より復元されました。





適切な資産保持の 確保

まだ使いたいけど、終わってしまう

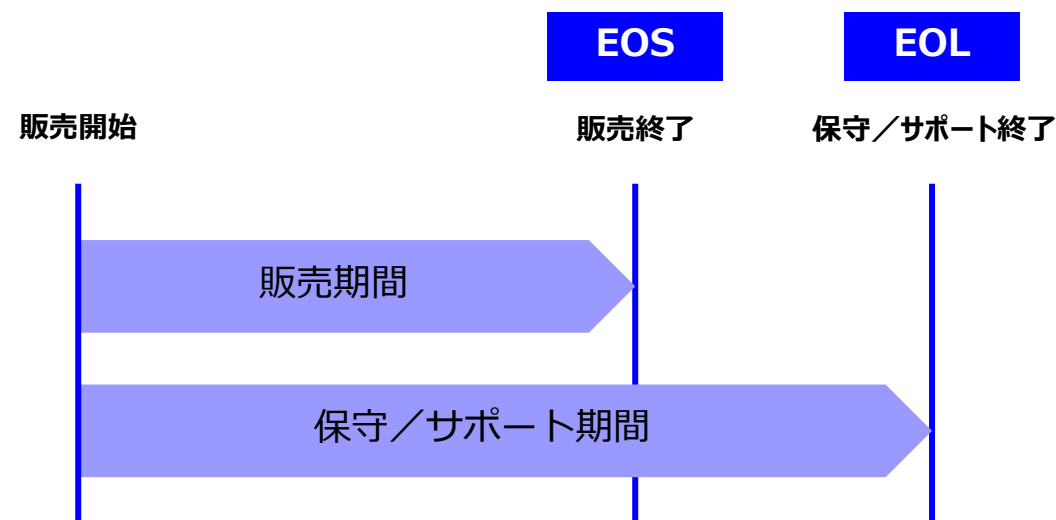
2.4 適切な資産保持の確保

2.4.1 サービスの終了

● サポート期間

EOS/EOL

- 製品のEOS（End of Sales）とは、製品・サービスは販売を終了する期限を指します。
- 製品のEOL（End of Life）とは、製品・サービスに関するサポートを受けることができなくなる期限を指します。
- 一般的には、EOSの後に一定の期間を設けてEOLが来ます。
- 製品の修理対応やサポートが受けられなくなり、不具合の修正・アップデートがされないため、セキュリティリスクの蓄積につながります。





データセキュリティ管理

スタンダードを定義しよう

2.5 データセキュリティ管理

2.5.1 データの状態

●スタンダードの決定

スタンダードは方向性を決めるものであるため、「保存中のデータ」や「転送中のデータ」などの状態に対する保護策を包括的に指定します。

ドキュメント区分	内容	例
ポリシー	実現したいことを明確にします。	機密データは暗号化して保護します。
スタンダード	ポリシーを達成する上で必要な要素を具体化します。	保存中のデータ にはディスク全体の暗号化を要求し、 転送中のデータ にはTLSを要求することで、機密データを保護します。
プロシージャ	どうやって達成するかをステップバイステップの手順です。	ディスク全体の暗号化する手順はステップ1～。

2.5 データセキュリティ管理

2.5.1 データの状態

●データの3状態

保存データ (data at rest)

- ディスクとしては利用可能を保持しながらデータの暗号化を行います。
- スマートフォンなどのモバイルディスクはフル暗号化をしておく方が安全です。
- 一時的なファイルやスワップスペースなどに対しては部分的な暗号化にしておく方が負荷が低くなります。

転送・送信データ (data in transit/motion)

- IPSEC、TLSなどネットワークトラフィックを維持しながらデータの暗号化を行います。

使用データ (data in use)

- 利用しているため暗号化することができません。
- 退席時のPC画面ロックなどポリシーに則ったルールによって、業務レベルで非開示する必要があります。



ディスク暗号化
テープ暗号化
AES

保存データ (data at rest)



IPSEC
TLS

転送・送信データ (data in transit/motion)



退席時のPC
画面ロックなど

使用データ (data in use)

2.5 データセキュリティ管理

2.5.2 スコーピングとテーラリング

● スコーピング

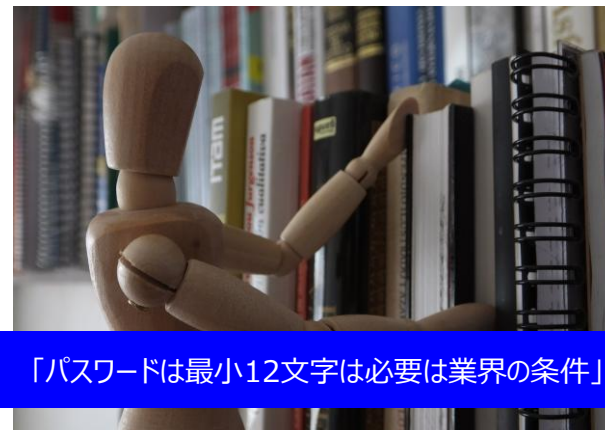
スコーピング

- 基本的なセキュリティ管理策を見直し、セキュリティ管理策を選択することです。
- 一般に、業界標準のスタンダードであるNISTやISO/IECを選定することが挙げられます。

● テーラリング

テーラリング

- 組織目標に沿うように、大枠のセキュリティ基本計画内を維持しつつもセキュリティ管理策を変更することを指します。
- NISTやISO/IECといった標準は、組織目標に完全に合っているわけではありません。組織目標をより効率的に達成するために調整が行われます。



「パスワードは最小12文字は必要は業界の条件」



「企業セキュリティ意識のため最小14文字に調整」

2.5 データセキュリティ管理

2.5.3 スタンドアードの選択

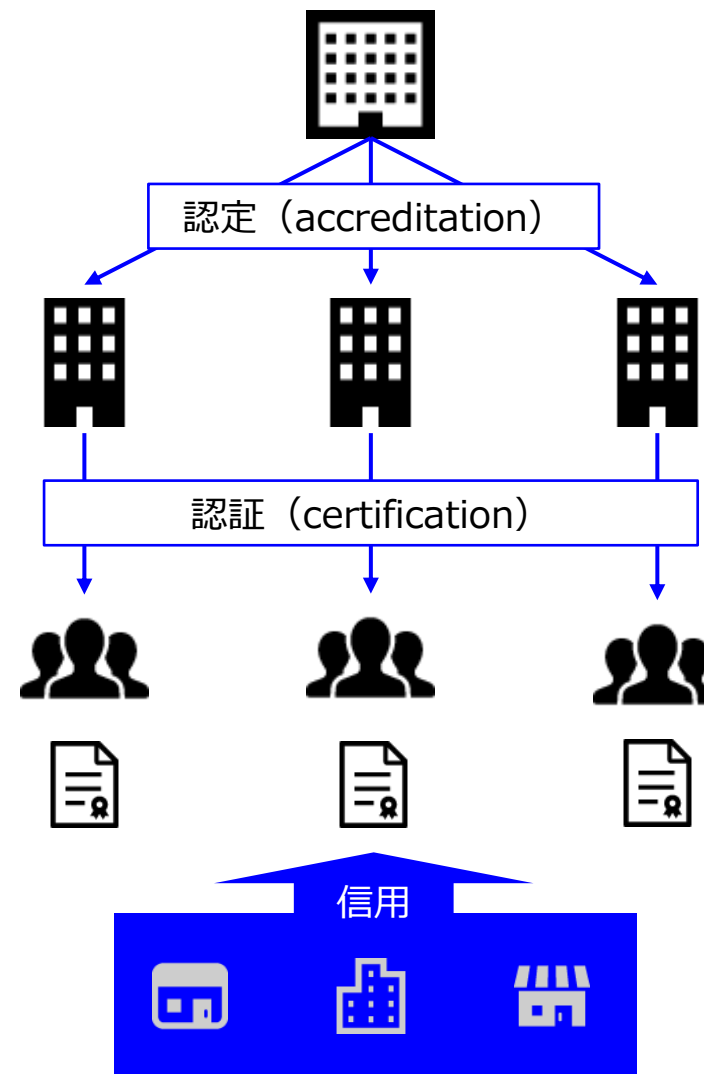
● 認証と認定

認証 (certification)

- ある製品・システム・組織が要件を満たしていることを確認することです。

認定 (accreditation)

- ある組織が組織を認証するに値するかを承認することです。



2.5 データセキュリティ管理

2.5.3 スタンドardsの選択

● セキュリティ評価基準

コンピューターシステムの信頼性を図るためのセキュリティ評価基準が必要になります。

TCSEC (Trusted Computer System Evaluation Criteria、オレンジブック)

- 米国国防総省下のNSA(国家安全保障局)内の NCSC(米国コンピュータセキュリティセンター)により策定された、軍用調達のための認証基準です。
- レインボーシリーズの一つであり、ドキュメントの色がオレンジであるためオレンジブックとも呼ばれる。

ITSEC (Information Technology Security Evaluation Criteria)

- 欧州統一評価基準として策定され評価基準です。TCSECは機密性だけを強調したこととは異なり、ITSECは完全性と可用性を包括しています。

コラム：書籍が色分けされているレインボーシリーズ

オレンジブックは、信頼できるシステムを定義しています。たまたまオレンジ色なのでオレンジブックと呼ばれています。

2.5 データセキュリティ管理

2.5.3 スタンドardsの選択

●セキュリティ評価基準

CC (Common Criteria、ISO/IEC 15408)

- TCSECとITSECが統合され、ISO/IECが策定した国際認証基準です。
- 評価ターゲット、プロテクション・プロファイル、セキュリティターゲットなどの定義がされています。

評価ターゲット (TOE、Target Of Evaluation)

- 診断対象となる製品やシステムです。

プロテクション・プロファイル (PP、Protection Profile)

- 製品やシステムに要求されるセキュリティ要件を記載するためのセキュリティ基本設計書のひな型です。
- PPは「OS」、「ファイアウォール」、「ICカード」などの製品技術分野ごとに作成され、セキュリティ要件を明示するために使われます。

セキュリティターゲット (ST、Security Target)

- PPのセキュリティ要件をTOEがどのように実現しているかを、製品提供者が提供するものです。



それはファイアウォール定義に
則るか？



ファイアウォールとしてのセキ
ュリティ機能を持つか？



どのように実装されているのか？

2.5 データセキュリティ管理

2.5.3 スタンドardsの選択

● 認証基準の目安

いくつかの評価基準がありますがおおよそ以下のような関係性になっています。

TCSEC		ITSEC		CC
D-C1	最低限のセキュリティ	E0-1	機能テスト	EAL1
C1(DAC)	裁量的	E1,F-C1	構造テスト（非公式の文書が必要）	EAL2
C2(DAC)	アクセス	E2-F-C2	方式テスト及びチェック（非公式の詳細設計書と構成管理が必要）	EAL3
B1(MAC)	ラベル	E3-F-B1	方式設計、テスト及びレビュー	EAL4
B2(MAC)	構築的	E4-F-B2	準形式的設計及びテスト（セキュリティポリシーの公式モデル）	EAL5
B3(MAC)	セキュリティ領域の区分化	E5-F-B3	準形式検証済み設計及びテスト（脆弱性試験にソースコードを用いる）	EAL6
A	保証済み	E6-F-B3	形式的検証済み設計及びテスト（試験知らずのドキュメント）	EAL7

2.5 データセキュリティ管理

2.5.4 データ保護システム

● デジタル著作権管理

デジタル著作権管理 (DRM、Digital Rights Management)

- デジタルコンテンツを使用および共有する方法を制御するための技術の総称です。
- コンテンツを他者に共有するとき、コンテンツ自体を盗まれ、拡散もしくは売買される可能性があるため、コンテンツ自体をコピーできなくさせたり、ローカルに保存できない機能を付与します。
- 例えば、Amazon Kindleでは、ハイライトした部分をコピー & ペーストする際に、回数制限があります。
- 商用DRMとして、FairPlay Streaming (Apple) 、Widevine (Google) 、PlayReady (Microsoft) があります。

● データ損失防止

データ損失防止 (DLP、Data Loss Prevention)

- データの流出や破壊を検出し、防止するための対策です。
- 一般的に、社内外の境界でネットワークトラフィックを分析し、機密情報の流出を抑止します。

音楽CD



- 音楽CDでは、SCMSと呼ばれるコピーガード機能がついています。
- SCMS (Serial Copy Management System) とは、コピーを1世代のみに制限する技術です。

ストリーミング配信



- ストリーミング配信では、利用者側のコンピュータにデータが残らないようになっています。
- 通信の傍受による漏洩を避けるため、復号キーでの認証を行っています。

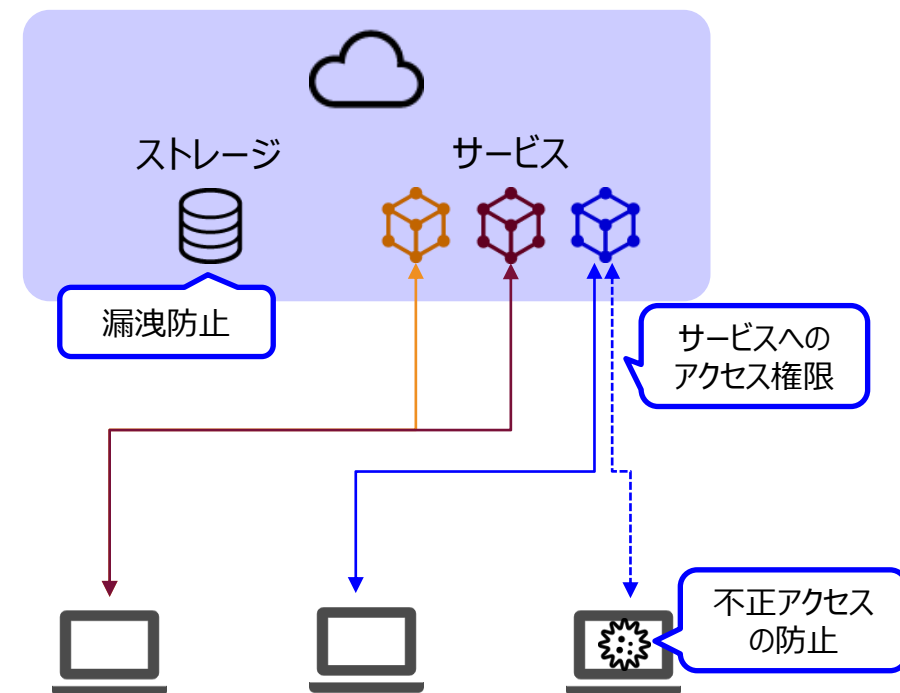
2.5 データセキュリティ管理

2.5.4 データ保護システム

● クラウド・アクセス・セキュリティ・ブロッカー

クラウド・アクセス・セキュリティ・ブロッカー（CASB、Cloud Access Security Broker）

- ユーザーとクラウドベースのリソース間のアクティビティを監視し、認証の制御、アクセスの承認、保存データの暗号化、すべてのアクセスのログ取得、疑わしいアクティビティに対するアラートなど、組織のセキュリティポリシーを適用するアプリケーションです。
- 利用ユーザーに対して認証を求め、不正な利用を防止します。
- クラウドとユーザー間で行われるすべてのアクティビティを監視、管理者が定義したセキュリティポリシーを適用します。
- クラウドストレージへの不審なアップロードやダウンロードの監視と、シャドーITの検知を行います。
- ユーザーのアクセス権限を設定して、データの持ち出しを防ぎます。



- クラウドへのデータ送信監視
- シャドーITからの不正検知
- アクセス権限の設定によるデータ持ち出し防止

2.5 データセキュリティ管理

2.5.5 個人情報保護

● 個人情報を加工して利活用

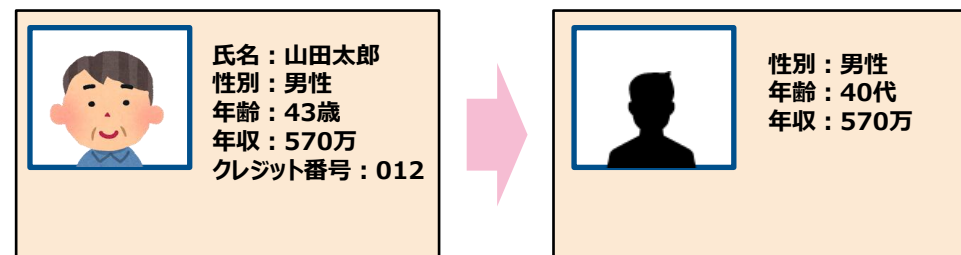
事業者が自社内部で利用するために、個人情報を加工して個人を特定できない情報に変換した場合でも、変換後の情報も個人情報に該当する場合があります。

匿名化

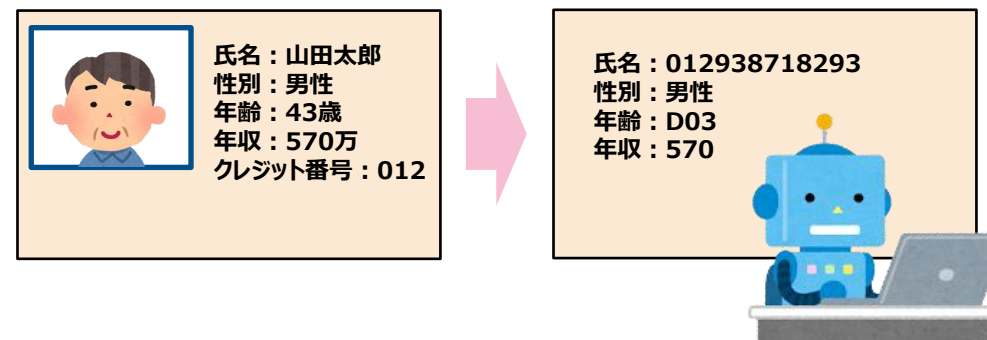
- 関連するデータをすべて削除して、元の対象者や個人を特定することが理論的に不可能になるようにすることです。

仮名化

- 他のデータを表現するために仮名を使用する事です。つまりは、他の文字に置き換えて元の情報をわからなくすることです。
- 仮名化された文字だけ見ると、誰なのかわかりませんが、仮名化の前と後の文字列は紐づいています。
- 仮名化をしてからAIなどの分析の入力データとして用いることで、分析中はデータそのものは個人情報としての管理を避けつつ、分析結果を得ることを想定しています。



匿名加工情報は、元の個人情報を復元できないように加工したものをいいます。



仮名加工情報は、他の情報と照合すれば、特定の個人を識別できる情報をいいます。
事業者内部における分析等に限定して利用します。

2.5 データセキュリティ管理

2.5.5 個人情報保護

● 個人情報を加工して利活用

紐づけることで個人の特定が可能なもの

- 生存する個人に関する情報であっても、個人情報、仮名加工情報、匿名加工情報のいずれにも該当しないものをいいます。たとえば、Cookieなどのような識別子情報があげられます。
- Cookieなどのような情報の第三者提供についての規制はありませんでした。しかし、Cookieなどのような情報は、他の情報と照合することにより容易に特定の個人を識別することができる場合があります。
- 具体的には、ある個人に関する、①Cookie等により収集されたウェブサイト閲覧履歴、②メールアドレスに結び付いた、個人の年齢・性別・家族構成、③サービス利用履歴、④位置情報、⑤個人の興味・関心を示す情報等の、ある個人に関する情報であるものの特定の個人を識別できないものをいいます。

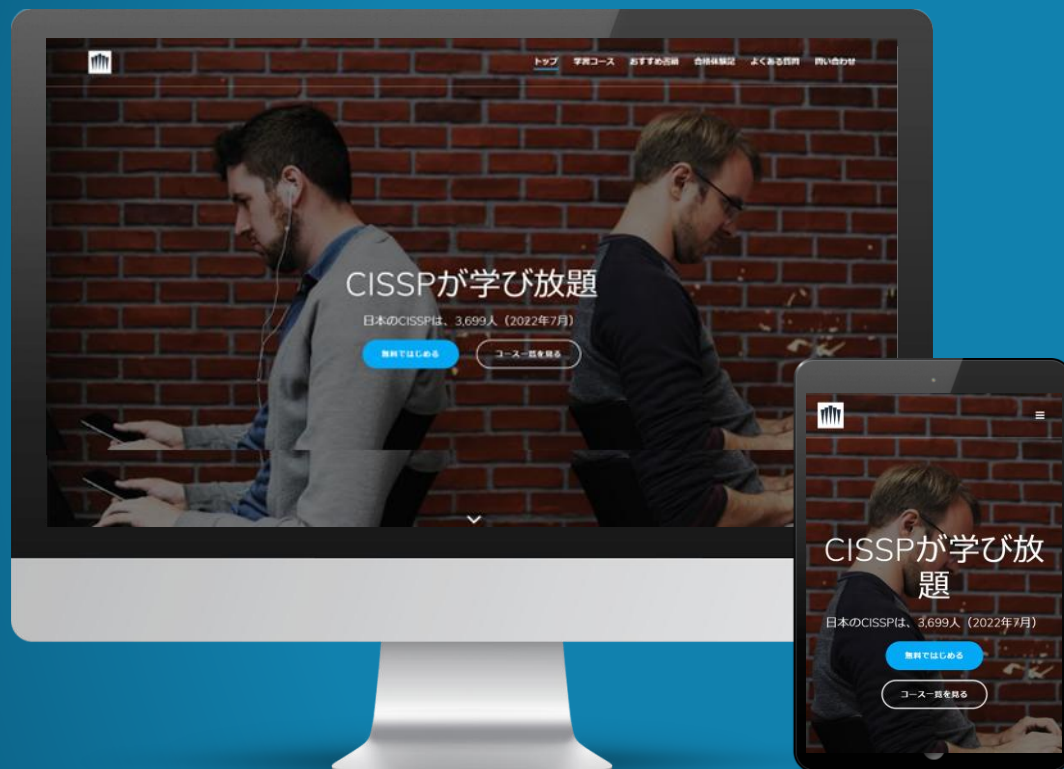
第三者同意は必要

- 第三者が個人データとして取得する場合には、提供元の事業者は本人の同意が得られているか等を確認する必要があります。

コラム：ホテルマリオットのデータ漏洩

大手ホテルチェーンのMarriott Internationalは、2018年に傘下のStarwood Hotelsグループの予約データベースに不正アクセスが発生し、最大で5億件のクレジットカード情報、生年月日、パスポート番号を含む宿泊客情報が流出していることがわかりました。スターウッド社のシステムでは、2014年にゲスト予約データベースにアクセスしようとする不審な試みを、内部のセキュリティツールがキャッチしていましたが、2018年にマリオット社はセキュリティツールのアラートから、スターウッド宿泊者予約データベースへの不正アクセスを検知しました。この事実認識から遅い対応により、ブランドの低下を著しく低下させる結果となってしまいました。これは2018年当時の話で、現在はセキュリティポリシーの見直しが行われ、デューデリジェンスの実施が行われているそうです。

PIEDPINの紹介



なぜセキュリティを学ぶのか

セキュリティの最も大きな敵は、人はあらゆるものに慣れ、そのリスクを考えなくなる習性にあります。セキュリティの学びを通して得られる貴重なものは、あらゆる事象に対して好奇心を持つことであり、それは目まぐるしい現代を生きるのに大いに役立つでしょう。

- EASY DESIGN
- SUPER EFFICIENT
- EVERYWHERE

PIEDPINを選ぶ理由



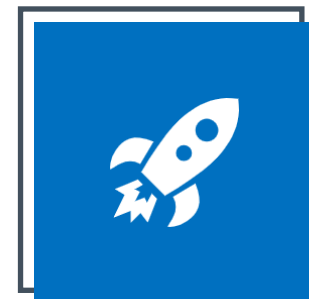
**EASY
DESIGN**

日本語で学べる



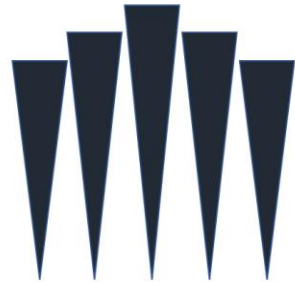
**SUPER
EFFICIENT**

わかりやすい説明



EVERYWHERE

どこからでも学べる環境



THANK YOU

Let's try CISSP!